

TRƯỜNG ĐẠI HỌC NGOẠI NGỮ - TIN HỌC THÀNH PHỐ HỒ CHÍ MINH
KHOA CÔNG NGHỆ THÔNG TIN
ୱ ୱ ୱ ୱ



BÁO CÁO ĐỒ ÁN MÔN HỌC
BẢO MẬT NGƯỜI DÙNG CUỐI

BẢO VỆ ENDPOINTS CHO DOANH NGHIỆP NHỎ

GVHD: ThS. Đỗ Phi Hưng

SV thực hiện: Trần Phan Cảnh Phúc - 23DH112758
Lê Huỳnh Quang Hậu - 23DH114302

Chuyên ngành: An Ninh Mạng

Khóa: Khóa 29 – K2023

TP. Hồ Chí Minh, tháng 8 năm 2026

LỜI CẢM ƠN

Xin chào thầy

Nhóm em xin được cảm ơn thầy trong suốt thời gian học tập vừa qua vì đã hỗ trợ chúng em hoàn thành việc hoàn tất báo cáo môn học này. Trong thời gian quý báu này chúng em được học tập và làm việc cùng nhau để đưa đến các phương án tốt nhất và hiệu quả nhất cho việc hoàn thành báo cáo. Việc chúng em có được những khoảng thời gian làm việc chuyên nghiệp với tinh thần làm việc và học tập vô cùng sung sức mà chúng em được truyền cảm hứng từ thầy và từ đây bọn em có thể hiểu được và cảm nhận được sự chuyên nghiệp trong phóng thái làm việc và học tập cực kì hiệu quả mà thầy đã truyền đạt lại cho chúng em ạ.

Chúng em chân thành cảm ơn thầy !

This image shows a full page of white paper with horizontal dotted lines. The lines are evenly spaced and run across the width of the page, providing a guide for handwriting practice. There are no margins, text, or other markings on the page.

Thành phố Hồ Chí Minh ... Tháng 7 năm 2026

Giảng viên hướng dẫn ký tên

(Ký tên, đóng dấu)

MỤC LỤC

LỜI CẢM ƠN	2
NHẬN XÉT CỦA GIẢNG VIÊN HƯỚNG DẪN	3
MỤC LỤC	4
DANH MỤC HÌNH ẢNH	6
DANH MỤC CÁC BẢNG BIỂU	7
DANH MỤC CÁC TỪ VIẾT TẮT.....	8
CHƯƠNG 1. CƠ SỞ LÝ THUYẾT VÀ PHÂN TÍCH YÊU CẦU	9
1.1. Tổng quan về bảo vệ endpoint.....	9
1.2. Bối cảnh doanh nghiệp giả định	9
1.3. Các rủi ro chính	10
1.4. Các thành phần bảo vệ.....	10
1.5. Mục tiêu và phạm vi	11
CHƯƠNG 2. THIẾT KẾ VÀ TRIỂN KHAI HỆ THỐNG	12
2.1. Kiến trúc mô hình.....	12
2.2. Cấu hình Microsoft Defender và Firewall.....	12
2.3. Phân quyền và chính sách tài khoản.....	13
2.4. Cấu hình Sysmon và Wazuh Agent.....	14
2.5. Cập nhật bản vá.....	15
2.6. Triển khai hệ thống giám sát tài nguyên bằng Prometheus và Grafana	16
CHƯƠNG 3. THỰC NGHIỆM VÀ ĐÁNH GIÁ	18
3.1. Kịch bản phát hiện tệp kiểm thử EICAR.....	18
3.1.1. Mục tiêu và thực hiện	18
3.1.2. Kết quả.....	20
3.2. Kịch bản brute-force RDP	20
3.2.1. Mục tiêu và thực hiện	20
3.2.2. Kết quả phát hiện và khóa tài khoản	21
3.2.3. Biện pháp giảm thiểu.....	22
3.3. Kịch bản tiến trình tiêu thụ CPU bất thường.....	23
3.3.1. Mục tiêu và thực hiện	23
3.3.2. Xử lý và kết quả.....	25

3.4. Tổng hợp kết quả	27
3.5. Đánh giá giải pháp	27
CHƯƠNG 4. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	29
4.1. Kết luận	29
4.2. Hướng phát triển	29
TÀI LIỆU THAM KHẢO	31

DANH MỤC HÌNH ẢNH

Hình 1. Sơ đồ Wazuh Server, hai Windows Endpoint và Kali Linux.....	12
Hình 2. Trạng thái Defender và ba profile Windows Firewall đang bật	13
Hình 3. Kết quả net accounts.....	14
Hình 4. Tài khoản ketoan thuộc nhóm Users/Remote Desktop Users	14
Hình 5. Hai Wazuh Agent ở trạng thái Active	15
Hình 6. Windows Update.....	15
Hình 7. Lịch sử bản cập nhật gần nhất	16
Hình 8. Dashboard Grafana hiển thị CPU của hai endpoint	17
Hình 9. Tạo file EICAR.....	18
Hình 10. Defender xóa tệp EICAR.....	19
Hình 11. Defender phát hiện EICAR.....	19
Hình 12. Event ID 1116 và cảnh báo tương ứng trên Wazuh	19
Hình 13. Event ID 1117 và cảnh báo tương ứng trên Wazuh	20
Hình 14. Quá trình thử đăng nhập RDP từ Kali	21
Hình 15. Danh sách các Event ID 4625 và chi tiết địa chỉ IP nguồn Kali	21
Hình 16. Kết quả net user ketoan hiển thị Account active: Locked	22
Hình 17. Rule Firewall giới hạn RDP chỉ có IP của admin.....	22
Hình 18. Kết quả Kali không còn kết nối được.....	23
Hình 19. Chỉ có admin mới đăng nhập RDP được	23
Hình 20. Grafana trước khi CPU tăng	24
Hình 21. Grafana sau khi CPU tăng	24
Hình 22. Task Manager trước script high_cpu.ps1 hoạt động.....	25
Hình 23. Task Manager trong khi script high_cpu.ps1 hoạt động.....	25
Hình 24. Wazuh hiển thị Process Create	26
Hình 25. Tìm PID của tiến trình đó để end task trên.....	26
Hình 26. End 3 tiến trình 4056, 7100, 3116	26
Hình 27. Khi end PID, CPU của 2 máy về lại ban đầu	27

DANH MỤC CÁC BẢNG BIỂU

Bảng 1. Mô tả doanh nghiệp.....	9
Bảng 2. Các rủi ro doanh nghiệp thường gặp phải.....	10
Bảng 3. Các thành phần bảo vệ	10
Bảng 4. Các máy sử dụng, vai trò và IP	12
Bảng 5. Tổng hợp kết quả thực nghiệm	27

DANH MỤC CÁC TỪ VIẾT TẮT

Viết tắt	Tên đầy đủ	Ý nghĩa
SIEM	Security Information and Event Management	Hệ thống quản lý và phân tích sự kiện bảo mật.
Sigma	Sigma Rule Format	Định dạng quy tắc phát hiện sự kiện bảo mật độc lập với nền tảng SIEM.
Sysmon	System Monitor	Công cụ giám sát và ghi nhận chi tiết hoạt động của hệ thống Windows.
RDP	Remote Desktop Protocol	Giao thức điều khiển máy tính từ xa do Microsoft phát triển.

CHƯƠNG 1. CƠ SỞ LÝ THUYẾT VÀ PHÂN TÍCH YÊU CẦU

1.1. Tổng quan về bảo vệ endpoint

Endpoint là các thiết bị người dùng cuối như máy tính để bàn và máy tính xách tay kết nối vào hệ thống doanh nghiệp. Đây là nơi người dùng trực tiếp mở email, tải tệp, truy cập Internet, sử dụng phần mềm nghiệp vụ và đăng nhập từ xa. Vì thường xuyên tương tác với dữ liệu bên ngoài, endpoint là một trong những mục tiêu phổ biến của mã độc, hành vi dò mật khẩu và phần mềm không được phép.

Bảo vệ endpoint là tập hợp chính sách và biện pháp kỹ thuật nhằm ngăn chặn, phát hiện và xử lý hoạt động nguy hiểm trên máy người dùng. Một giải pháp cơ bản cần kết hợp antivirus, firewall, cập nhật bản vá, phân quyền, chính sách tài khoản và giám sát nhật ký. Các lớp này hỗ trợ lẫn nhau thay vì hoạt động độc lập.

1.2. Bối cảnh doanh nghiệp giả định

Đề tài xây dựng bối cảnh Công ty ABC hoạt động trong lĩnh vực thương mại điện tử với 30 nhân viên. Công ty xử lý thông tin khách hàng, đơn hàng, hóa đơn, hợp đồng và tài khoản truy cập các nền tảng kinh doanh. Phần lớn nhân viên sử dụng Windows 10 hoặc Windows 11, trong khi bộ phận công nghệ thông tin có thêm một số máy Linux phục vụ quản trị.

Bảng 1. Mô tả doanh nghiệp

Bộ phận	Số người	Thiết bị	Dữ liệu chính
Ban giám đốc	3	Windows 11	Hợp đồng, kế hoạch
Kế toán	5	Windows 10/11	Hóa đơn, bảng lương
Kinh doanh	10	Windows 10/11	Khách hàng, báo giá
Chăm sóc khách hàng	7	Windows 10	Đơn hàng, liên hệ
Công nghệ thông tin	5	Windows/Linux	Tài khoản, cấu hình, log

1.3. Các rủi ro chính

Hoạt động hằng ngày của nhân viên tạo ra nhiều rủi ro. Người dùng có thể tải nhầm tệp độc hại từ email hoặc Internet; dịch vụ RDP có thể bị dò mật khẩu; tiến trình bất thường có thể chạy nền và tiêu thụ tài nguyên; máy chưa cập nhật có thể tồn tại lỗ hổng đã biết; tài khoản có quyền quản trị quá mức làm tăng thiệt hại khi bị chiếm quyền. Ngoài ra, log nằm rải rác trên từng máy khiến quản trị viên khó theo dõi sự cố.

Bảng 2. Các rủi ro doanh nghiệp thường gặp phải

Rủi ro	Khả năng	Tác động	Mức đánh giá
Tệp độc hại	Cao	Cao	Cao
Brute-force RDP	Trung bình	Cao	Cao
Tiến trình bất thường	Trung bình	Trung bình	Trung bình
Thiếu bản vá	Cao	Cao	Cao
Lạm dụng quyền quản trị	Trung bình	Cao	Cao
Không giám sát log	Trung bình	Cao	Cao

1.4. Các thành phần bảo vệ

Microsoft Defender Antivirus được sử dụng để phát hiện, cách ly và loại bỏ tệp nghi ngờ. Windows Defender Firewall kiểm soát kết nối đến endpoint và giới hạn dịch vụ RDP. Windows Update xử lý các lỗ hổng đã có bản vá. Tài khoản Standard User và Account Lockout Policy giảm nguy cơ lạm dụng quyền hoặc dò mật khẩu. Sysmon ghi nhận chi tiết tiến trình, còn Wazuh Agent chuyển nhật ký về Wazuh Server để phân tích tập trung.

Bảng 3. Các thành phần bảo vệ

Thành phần	Chức năng
Microsoft Defender Antivirus	Phát hiện và xử lý mã độc
Windows Defender Firewall	Kiểm soát kết nối mạng
Windows Update	Cập nhật bản vá
Standard User	Áp dụng quyền tối thiểu
Account Lockout Policy	Khóa tài khoản sau nhiều lần sai
Sysmon	Ghi log tiến trình và kết nối

Wazuh	Thu thập, phân tích và hiển thị cảnh báo
Grafana	Giám sát CPU của các máy

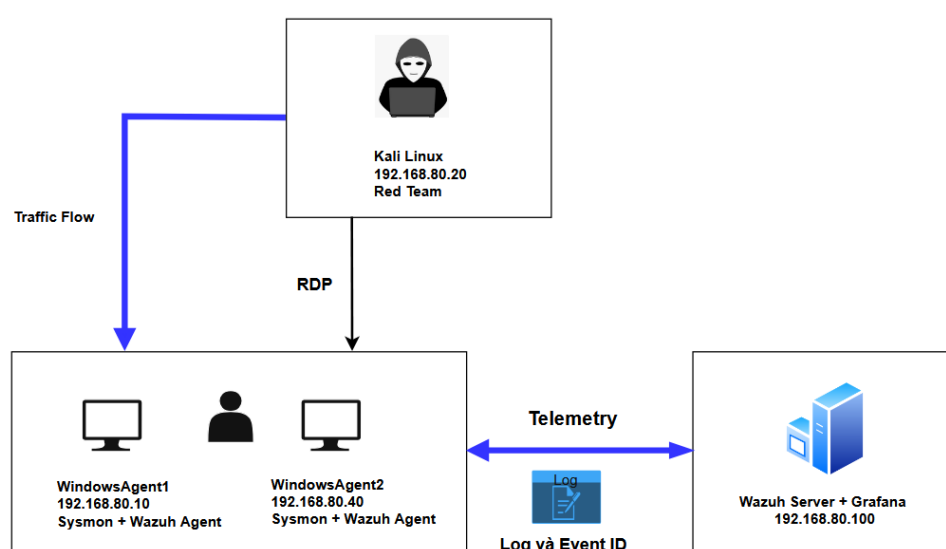
1.5. Mục tiêu và phạm vi

Mục tiêu của đề tài là xây dựng mô hình bảo vệ endpoint phù hợp doanh nghiệp nhỏ, triển khai tối thiểu hai máy người dùng và chứng minh khả năng phát hiện hoặc giảm thiểu ba rủi ro thực tế. Phạm vi thực hành gồm hai endpoint Windows, một máy Kali Linux và một Wazuh Server. Mọi thao tác kiểm thử chỉ được thực hiện trong mạng lab do nhóm quản lý.

CHƯƠNG 2. THIẾT KẾ VÀ TRIỂN KHAI HỆ THỐNG

2.1. Kiến trúc mô hình

Mô hình gồm Wazuh Server tại địa chỉ 192.168.80.100, hai endpoint Windows và một máy Kali Linux. Hai endpoint cài Defender, Firewall, Sysmon và Wazuh Agent. Agent đọc Security Log, Defender Operational Log và Sysmon Operational Log rồi gửi sự kiện về Wazuh Server qua cổng 1514/TCP. Kali chỉ đóng vai trò máy kiểm thử và không phải thành phần bảo vệ.



Hình 1. Sơ đồ Wazuh Server, hai Windows Endpoint và Kali Linux

Bảng 4. Các máy sử dụng, vai trò và IP

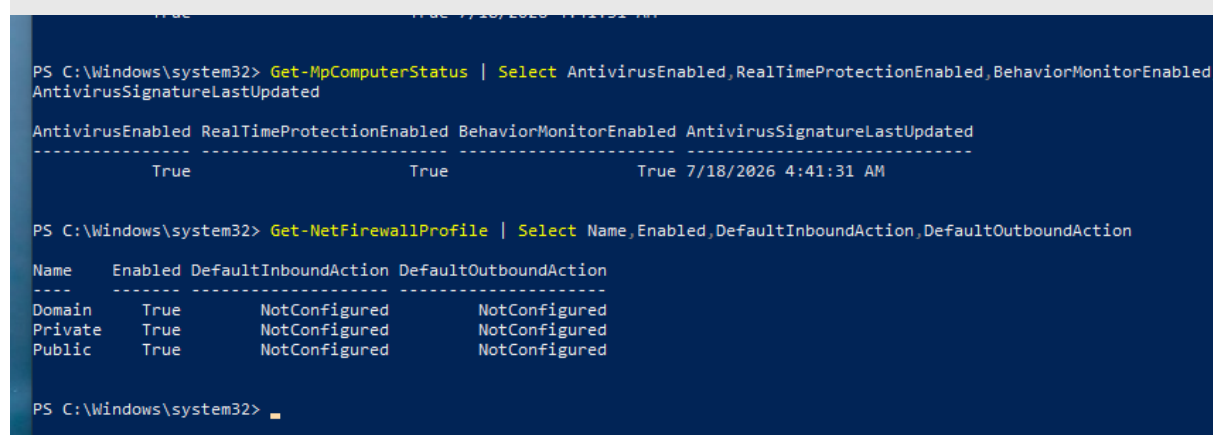
Máy	Vai trò	Địa chỉ IP
Wazuh Server, Grafana	Giám sát và phân tích log	192.168.80.100
Windows Endpoint 1	Máy người dùng kế toán	192.168.80.40
Windows Endpoint 2	Máy người dùng sale	192.168.80.10
Kali Linux	Máy kiểm thử	192.168.80.20

2.2. Cấu hình Microsoft Defender và Firewall

Trên hai endpoint, Microsoft Defender được bật bảo vệ thời gian thực, giám sát hành vi và cập nhật chữ ký. Windows Firewall được bật trên các profile Domain, Private và Public. Log kết nối bị chặn được kích hoạt để hỗ trợ điều tra. Trong giai đoạn tạo log

RDP, rule Remote Desktop được bật tạm thời; sau thử nghiệm, hệ thống chỉ cho phép địa chỉ quản trị truy cập cổng 3389.

```
Get-MpComputerStatus | Select
AntivirusEnabled,RealTimeProtectionEnabled,BehaviorMonitorEnabled,AntivirusSignature
LastUpdated
Update-MpSignature
Set-NetFirewallProfile -Profile Domain,Private,Public -Enabled True
Get-NetFirewallProfile | Select
Name,Enabled,DefaultInboundAction,DefaultOutboundAction
```



```
PS C:\Windows\system32> Get-MpComputerStatus | Select AntivirusEnabled,RealTimeProtectionEnabled,BehaviorMonitorEnabled
AntivirusSignatureLastUpdated

AntivirusEnabled RealTimeProtectionEnabled BehaviorMonitorEnabled AntivirusSignatureLastUpdated
-----
True True True 7/18/2026 4:41:31 AM

PS C:\Windows\system32> Get-NetFirewallProfile | Select Name,Enabled,DefaultInboundAction,DefaultOutboundAction

Name Enabled DefaultInboundAction DefaultOutboundAction
-----
Domain True NotConfigured NotConfigured
Private True NotConfigured NotConfigured
Public True NotConfigured NotConfigured

PS C:\Windows\system32>
```

Hình 2. Trạng thái Defender và ba profile Windows Firewall đang bật

2.3. Phân quyền và chính sách tài khoản

Nhân viên sử dụng tài khoản thường và không thuộc nhóm Administrators. Tài khoản ketoan được tạo trên Endpoint 1 và được cấp quyền đăng nhập RDP phục vụ kiểm thử. Chính sách khóa tài khoản được đặt ở ngưỡng năm lần sai, thời gian khóa 15 phút và cửa sổ quan sát 15 phút. Cấu hình này làm chậm hoạt động dò mật khẩu nhưng vẫn cần kết hợp Firewall để chặn nguồn truy cập.

```
net accounts /lockoutthreshold:5
net accounts /lockoutduration:15
net accounts /lockoutwindow:15
net accounts
```

```

The command completed successfully.

PS C:\Windows\system32> net accounts /lockoutwindow:2
The command completed successfully.

PS C:\Windows\system32> net accounts /lockoutduration:2
The command completed successfully.

PS C:\Windows\system32> net accounts /lockoutthreshold:5
The command completed successfully.

PS C:\Windows\system32> net accounts
Force user logoff how long after time expires?:      Never
Minimum password age (days):                       0
Maximum password age (days):                       42
Minimum password length:                            0
Length of password history maintained:               None
Lockout threshold:                                  5
Lockout duration (minutes):                          2
Lockout observation window (minutes):                2
Computer role:                                       WORKSTATION
The command completed successfully.

PS C:\Windows\system32>

```

Hình 3. Kết quả net accounts

```

groupname name [...] [/ADD | /DELETE] [/DOMAIN]

PS C:\Windows\system32> net user ketoan
User name                ketoan
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        7/17/2026 1:13:43 PM
Password expires         8/28/2026 1:13:43 PM
Password changeable      7/17/2026 1:13:43 PM
Password required        Yes
User may change password No

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               7/19/2026 7:52:09 PM

Logon hours allowed      All

Local Group Memberships  *Remote Desktop Users *Users
Global Group memberships *None
The command completed successfully.

PS C:\Windows\system32>

```

Hình 4. Tài khoản ketoan thuộc nhóm Users/Remote Desktop Users

2.4. Cấu hình Sysmon và Wazuh Agent

Sysmon được cài trên hai endpoint để ghi nhận sự kiện tạo tiến trình. Wazuh Agent được cấu hình thu thập Security Log, Windows Defender Operational và Sysmon Operational. Sau khi sửa ossec.conf, dịch vụ WazuhSvc được khởi động lại. Dashboard phải hiển thị cả hai agent ở trạng thái Active trước khi bắt đầu các kịch bản.

```

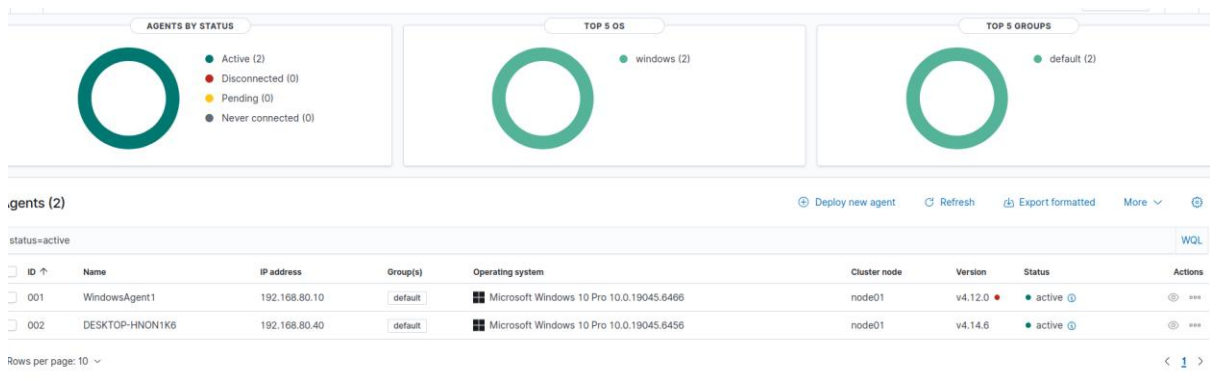
<localfile>
  <location>Security</location>

```

```

<log_format>eventchannel</log_format>
</localfile>
<localfile>
  <location>Microsoft-Windows-Windows Defender/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>

```



Hình 5. Hai Wazuh Agent ở trạng thái Active

2.5. Cập nhật bản vá

Windows Update được kiểm tra trên hai endpoint và các bản cập nhật quan trọng được cài đặt trước khi thử nghiệm. Lịch sử cập nhật được sử dụng làm minh chứng cho lớp quản lý bản vá. Trong doanh nghiệp thật, việc cập nhật cần có lịch bảo trì và cơ chế triển khai tập trung để tránh phụ thuộc thao tác thủ công trên từng máy.



Hình 6. Windows Update

```

PS C:\Windows\system32> Get-HotFix |
>> Sort-Object InstalledOn -Descending |
>> Select-Object -First 10

Source      Description      HotFixID      InstalledBy      InstalledOn
-----
DESKTOP-HN... Security Update  KB5072653     NT AUTHORITY\SYSTEM  7/18/2026 12:00:00 AM
DESKTOP-HN... Update      KB5066130     NT AUTHORITY\SYSTEM  7/13/2026 12:00:00 AM
DESKTOP-HN... Security Update  KB5066791     NT AUTHORITY\SYSTEM  7/13/2026 12:00:00 AM
DESKTOP-HN... Security Update  KB5066790     NT AUTHORITY\SYSTEM  7/8/2026 12:00:00 AM
DESKTOP-HN... Update      KB5066135     NT AUTHORITY\SYSTEM  6/2/2026 12:00:00 AM
DESKTOP-HN... Update      KB5011048     NT AUTHORITY\SYSTEM  6/2/2026 12:00:00 AM
DESKTOP-HN... Update      KB5015684     NT AUTHORITY\SYSTEM  12/4/2023 12:00:00 AM
DESKTOP-HN... Update      KB5032907     NT AUTHORITY\SYSTEM  12/4/2023 12:00:00 AM
DESKTOP-HN... Security Update  KB5014032     NT AUTHORITY\SYSTEM  12/4/2023 12:00:00 AM

PS C:\Windows\system32>

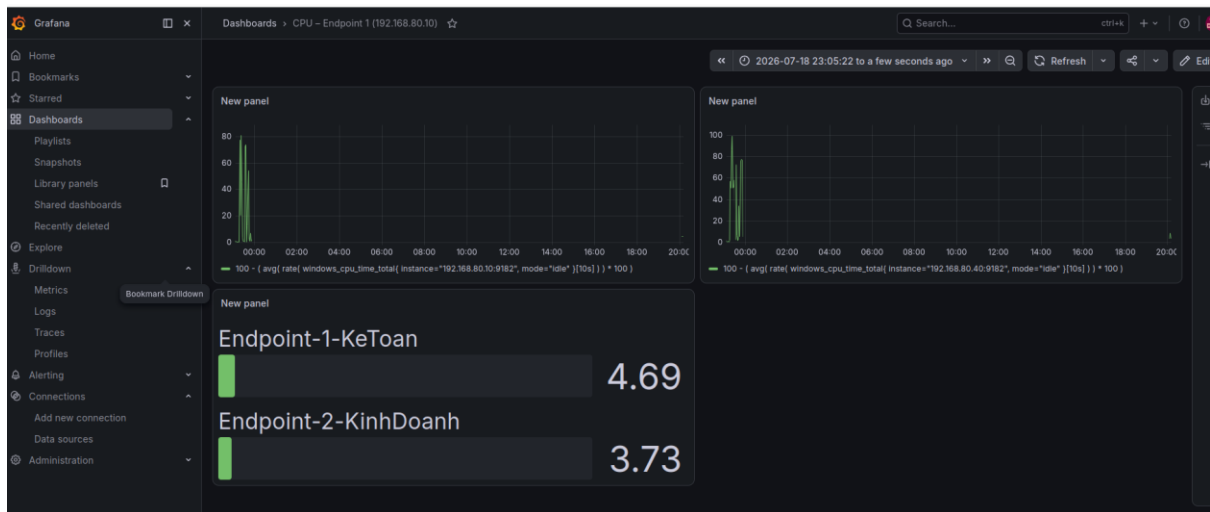
```

Hình 7. Lịch sử bản cập nhật gần nhất

2.6. Triển khai hệ thống giám sát tài nguyên bằng Prometheus và Grafana

Để hỗ trợ phát hiện sớm các bất thường về hiệu năng endpoint, nhóm triển khai Prometheus kết hợp Windows Exporter và Grafana. Windows Exporter được cài trên các endpoint Windows để thu thập các chỉ số như CPU, RAM, Disk và Network. Prometheus định kỳ thu thập các chỉ số này, còn Grafana hiển thị dưới dạng Dashboard theo thời gian thực. Hệ thống giúp quản trị viên nhanh chóng phát hiện endpoint có dấu hiệu sử dụng tài nguyên bất thường trước khi tiến hành điều tra nguyên nhân bằng Wazuh.

Thành phần	Chức năng
Windows Exporter	Thu thập CPU, RAM, Disk, Network
Prometheus	Thu thập và lưu trữ metrics
Grafana	Hiển thị Dashboard và biểu đồ
Wazuh	Điều tra log và phản ứng sự cố



Hình 8. Dashboard Grafana hiển thị CPU của hai endpoint

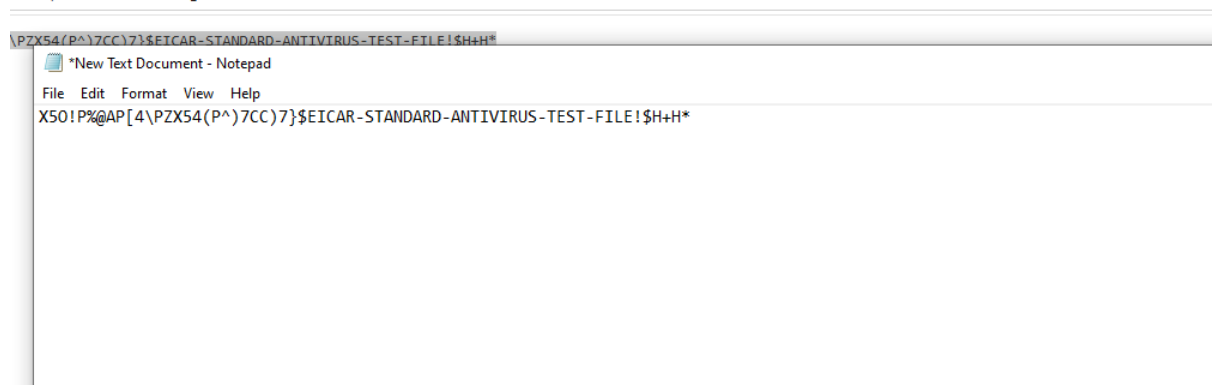
CHƯƠNG 3. THỰC NGHIỆM VÀ ĐÁNH GIÁ

3.1. Kịch bản phát hiện tệp kiểm thử EICAR

3.1.1. Mục tiêu và thực hiện

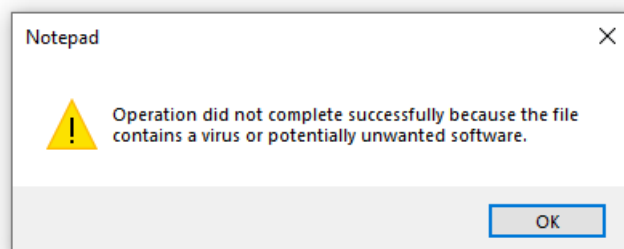
Kịch bản kiểm tra khả năng phát hiện và xử lý tệp nghi ngờ trên Endpoint 1. Khi người dùng tải hoặc tạo tệp kiểm thử EICAR, Microsoft Defender phải phát hiện và ngăn tệp trước khi thực thi. EICAR chỉ là chuỗi kiểm thử antivirus, không phải mã độc thật.

Trước thử nghiệm, nhóm kiểm tra Real-time Protection và thời gian cập nhật chữ ký. Sau khi tạo tệp, nhóm mở Protection History, Defender Operational Log và Wazuh Dashboard để kiểm tra sự kiện. Các Event ID cần chú ý là 1116 đối với phát hiện và 1117 đối với hành động xử lý.



Hình 9. Tạo file EICAR





Hình 10. Defender xóa tệp EICAR

```
PS C:\Windows\system32> Get-MpThreatDetection |
>> Select-Object ThreatID,
>> ThreatStatusID,
>> InitialDetectionTime,
>> Resources
PS C:\Windows\system32> Get-MpThreatDetection |
>> Select-Object ThreatID,
>> ThreatStatusID,
>> InitialDetectionTime,
>> Resources
```

ThreatID	ThreatStatusID	InitialDetectionTime	Resources
2147519003	3	7/18/2026 10:53:46 AM	{file:_C:\Users\ketoan\Downloads\eicar.com.txt.txt}
2147519003	3	7/18/2026 10:54:43 AM	{file:_C:\Users\ketoan\Downloads\New Text Document.txt}
2147519003	3	7/18/2026 10:53:40 AM	{file:_C:\Users\ketoan\Downloads\eicar.com.txt.txt}

```
PS C:\Windows\system32>
```

Hình 11. Defender phát hiện EICAR

data.win.system.eventID	1116
data.win.system.eventRecordID	780
data.win.system.keywords	0x8000000000000000
data.win.system.level	3
data.win.system.message	"Microsoft Defender Antivirus has detected malware or other potentially unwanted software. For more information please see the following: https://go.microsoft.com/fwlink/?linkid=37020&name=Virus:DOS/EICAR_Test_File&threatid=2147519003&enterprise=0 Name: Virus:DOS/EICAR_Test_File TN: 2147519003
data.win.system.opcode	0
data.win.system.processID	2312
data.win.system.providerGuid	{11cd958a-c507-4ef3-b3f2-5fd9dfbd2c78}
data.win.system.providerName	Microsoft-Windows-Windows Defender

Hình 12. Event ID 1116 và cảnh báo tương ứng trên Wazuh

data.win.system.computer	DESKTOP-1100110
data.win.system.eventID	1117
data.win.system.eventRecordID	781
data.win.system.keywords	0x8000000000000000
data.win.system.level	4
data.win.system.message	"Microsoft Defender Antivirus has detected malware or potentially unwanted software using Defender security intelligence and applied the remediation action defined in the security settings. For more information please see the following: https://go.microsoft.com/fwlink/?linkid=37020&name=Virus:DOS/EICAR_Test_File&threatid=2147519003&enterprise=0 Name: Virus-DOS/EICAR_Test_File
data.win.system.opcode	0
data.win.system.processID	2312
data.win.system.providerGuid	{11cd958a-c507-4ef3-b3f2-5fd9dfbd2c78}
data.win.system.providerName	Microsoft-Windows-Windows Defender

Hình 13. Event ID 1117 và cảnh báo tương ứng trên Wazuh

3.1.2. Kết quả

Microsoft Defender đã hiển thị cảnh báo trên endpoint và xử lý tệp kiểm thử. Kịch bản chứng minh Defender là thành phần ngăn chặn trực tiếp, còn Wazuh có vai trò tập trung nhật ký và hỗ trợ quản trị viên theo dõi sự cố.

3.2. Kịch bản brute-force RDP

3.2.1. Mục tiêu và thực hiện

Kịch bản mô phỏng nhiều lần xác thực RDP thất bại từ máy Kali tới Endpoint 1 tại địa chỉ 192.168.80.40. Tài khoản mục tiêu là ketoan. Nhóm sử dụng Hydra để tạo các lần thử và FreeRDP để kiểm tra có kiểm soát. Do module RDP của Hydra mang tính thử nghiệm, bằng chứng chính được lấy từ Security Log trên Windows và Wazuh.


```
C:\Windows\system32>net user ketoan
User name          ketoan
Full Name
Comment
User's comment
Country/region code 000 (System Default)
Account active      Locked
Account expires     Never

Password last set    7/17/2026 1:13:43 PM
Password expires     8/28/2026 1:13:43 PM
Password changeable  7/17/2026 1:13:43 PM
Password required    Yes
User may change password Yes

Workstations allowed All
Logon script
User profile
Home directory
Last logon           7/18/2026 4:57:56 PM
```

Hình 16. Kết quả net user ketoan hiển thị Account active: Locked

3.2.3. Biện pháp giảm thiểu

Khóa tài khoản chỉ ngăn tài khoản bị sử dụng, nhưng máy Kali vẫn có thể tiếp tục kết nối cổng 3389 và thử tài khoản khác. Vì vậy, sau khi thu thập đủ log, nhóm tắt các rule RDP mặc định và tạo rule chỉ cho phép địa chỉ quản trị. Khi Kali kiểm tra lại, cổng RDP không còn truy cập được từ nguồn không được phép.

```
Disable-NetFirewallRule -DisplayGroup "Remote Desktop"
New-NetFirewallRule -DisplayName "Allow RDP from authorized administrator" -
Direction Inbound -Protocol TCP -LocalPort 3389 -RemoteAddress 192.168.80.100 -
Action Allow
```

```
Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> Disable-NetFirewallRule -DisplayGroup "Remote Desktop"
PS C:\Windows\system32> New-NetFirewallRule -DisplayName "Allow RDP from authorized administrator" -Direction
Protocol TCP -LocalPort 3389 -RemoteAddress 192.168.80.100 -Action Allow

Name                : {afa9c115-b017-4c60-8d35-3a396fe61821}
DisplayName          : Allow RDP from authorized administrator
Description          :
DisplayGroup         :
Group               :
Enabled              : True
Profile              : Any
Platform             : {}
Direction            : Inbound
Action               : Allow
EdgeTraversalPolicy  : Block
LooseSourceMapping   : False
LocalOnlyMapping     : False
Owner                :
PrimaryStatus        : OK
Status               : The rule was parsed successfully from the store. (65536)
EnforcementStatus    : NotApplicable
PolicyStoreSource     : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses :
PolicyAppId          :
```

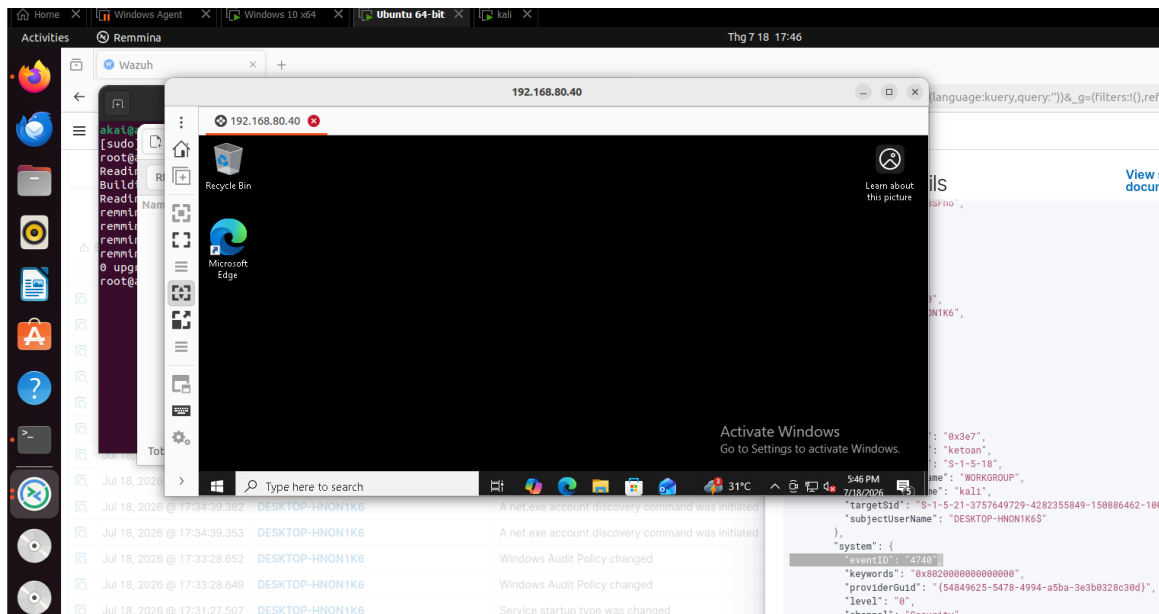
Hình 17. Rule Firewall giới hạn RDP chỉ có IP của admin

```
(kali@kali)-[~]
$ hydra \
-L ~/Capstone/users.txt \
-P ~/Capstone/passwords.txt \
-rdp://192.168.80.40 \
-t 1 -V

Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-18 02:41:52
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting
re
[DATA] max 1 task per 1 server, overall 1 task, 60 login tries (l:6/p:10), ~60 tries per task
[DATA] attacking rdp://192.168.80.40:3389/
[ATTEMPT] target 192.168.80.40 - login "ketoan" - pass "ePassword123" - 1 of 60 [child 0] (0/0)
[ERROR] freerdp: The connection failed to establish.
[ATTEMPT] target 192.168.80.40 - login "ketoan" - pass "Admin@123" - 2 of 61 [child 0] (0/1)
[STATUS] 2.00 tries/min, 2 tries in 00:01h, 59 to do in 00:30h, 1 active
[ERROR] freerdp: The connection failed to establish.
[ATTEMPT] target 192.168.80.40 - login "ketoan" - pass "Welcome123" - 3 of 62 [child 0] (0/2)
```

Hình 18. Kết quả Kali không còn kết nối được

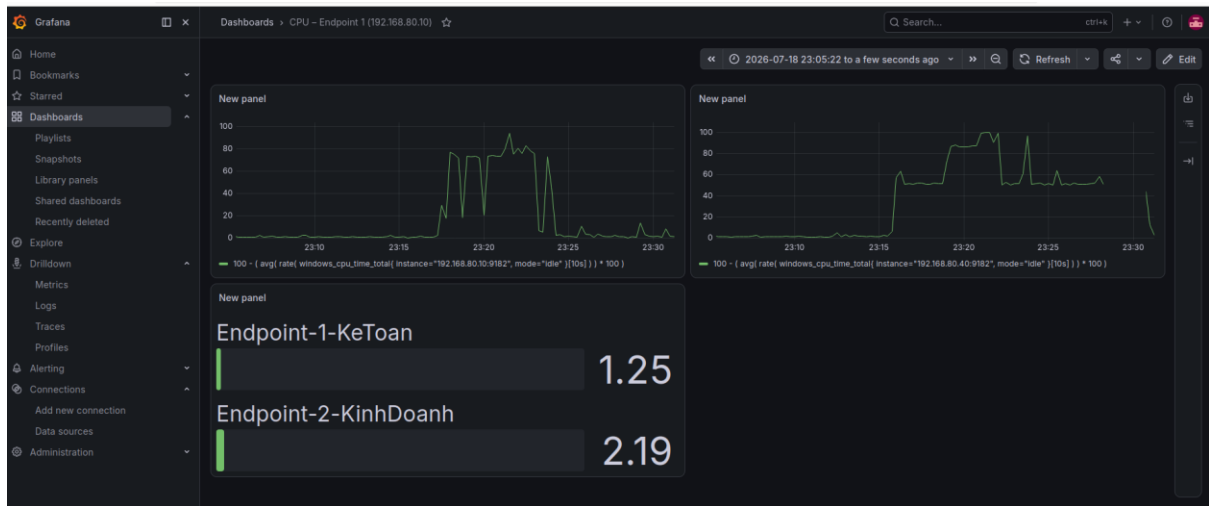


Hình 19. Chỉ có admin mới đăng nhập RDP được

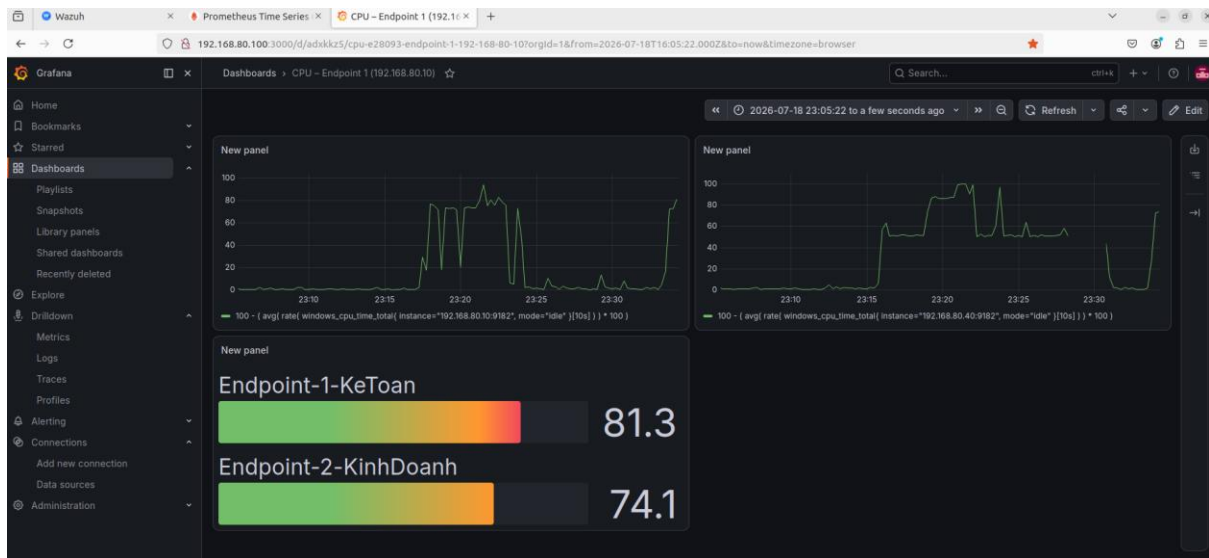
3.3. Kịch bản tiến trình tiêu thụ CPU bất thường

3.3.1. Mục tiêu và thực hiện

Trước khi chạy script, quản trị viên theo dõi Dashboard Grafana để ghi nhận trạng thái hoạt động bình thường của endpoint. Sau khi script high_cpu.ps1 được thực thi, Grafana ghi nhận mức sử dụng CPU tăng lên bất thường. Quản trị viên sử dụng Wazuh để điều tra sự kiện Sysmon Event ID 1 nhằm xác định tiến trình, Process ID, Command Line và tài khoản thực thi.



Hình 20. Grafana trước khi CPU tăng



Hình 21. Grafana sau khi CPU tăng

Kịch bản tạo một script PowerShell an toàn chạy trong thời gian giới hạn để làm CPU tăng cao. Trước khi chạy, nhóm chụp Task Manager làm đường cơ sở. Khi script hoạt động, Task Manager được sử dụng để xác định powershell.exe

Processes	Name	Status	CPU	Memory	Disk	Network
	Codex	Efficiency ...	6%	79%	2%	0%
	mksandbox.exe		0%	281.2 MB	0 MB/s	0 Mbps
	Zalo.exe (32 bit)		0%	235.5 MB	0 MB/s	0 Mbps
	VMware mksandbox		0%	192.7 MB	0 MB/s	0 Mbps
	Antimalware Service Executable		0%	188.9 MB	0 MB/s	0 Mbps
	mksandbox.exe		0%	177.2 MB	0 MB/s	0 Mbps
	Windows Explorer		0%	122.5 MB	0 MB/s	0 Mbps
	ChatGPT.exe		0%	106.8 MB	0 MB/s	0 Mbps
	Secure System		0%	94.8 MB	0 MB/s	0 Mbps
	Codex		0%	93.1 MB	0 MB/s	0 Mbps
	Task Manager		0%	78.9 MB	0 MB/s	0 Mbps
	Desktop Window Manager		0%	65.0 MB	0.9 MB/s	0 Mbps
	Renderer	Efficiency ...	0%	59.2 MB	0 MB/s	0 Mbps
	GPU Process		0%	48.0 MB	0 MB/s	0 Mbps
	vmware.exe (32 bit)		0%	44.3 MB	0 MB/s	0 Mbps
			0%	36.8 MB	0 MB/s	0 Mbps

Hình 22. Task Manager trước script high_cpu.ps1 hoạt động

Name	Status	CPU	Memory	Disk	Network	GPU	GPU engine	Power usage	Power usage t...
Windows Command Processor ...		81%	31.4 MB	0 MB/s	0 Mbps	0%		Very high	High
Task Manager		8.3%	15.2 MB	0.1 MB/s	0 Mbps	0%		Low	Very low
A Prometheus exporter for Win...		1.5%	10.3 MB	0 MB/s	0 Mbps	0%		Very low	Very low
System interrupts		0.7%	0 MB	0 MB/s	0 Mbps	0%		Very low	Very low
Antimalware Service Executable		0.5%	23.6 MB	0 MB/s	0 Mbps	0%		Very low	Very low
Service Host: Remote Procedure...		0.5%	3.5 MB	0 MB/s	0 Mbps	0%		Very low	Very low
System		0.5%	0 MB	0.1 MB/s	0 Mbps	0%		Very low	Very low
Desktop Window Manager		0.4%	10.9 MB	0 MB/s	0 Mbps	0.9%	GPU 0 - 3D	Very low	Very low
Windows Explorer		0%	17.7 MB	0 MB/s	0 Mbps	0%		Very low	Very low
Service Host: DCOM Server Proc...		0%	2.0 MB	0 MB/s	0 Mbps	0%		Very low	Very low
Services and Controller app		0%	1.7 MB	0 MB/s	0 Mbps	0%		Very low	Very low
Start		0%	1.0 MB	0 MB/s	0 Mbps	0%		Very low	Very low
Search		0%	0 MB	0 MB/s	0 Mbps	0%		Very low	Very low
Microsoft OneDriveFile Co-Aut...		0%	0.4 MB	0 MB/s	0 Mbps	0%		Very low	Very low
Service Host: Local System (Net...		0%	0 MB	0 MB/s	0 Mbps	0%		Very low	Very low

Hình 23. Task Manager trong khi script high_cpu.ps1 hoạt động

3.3.2. Xử lý và kết quả

Sau khi Grafana phát hiện endpoint có mức sử dụng CPU tăng bất thường, quản trị viên truy cập Wazuh Dashboard để điều tra nguyên nhân. Dựa trên log Sysmon Event ID 1, Wazuh hiển thị tên tiến trình, Process ID, Command Line và tài khoản thực thi. Hệ thống Wazuh Active Response được cấu hình để thực thi script trên endpoint nhằm dừng đúng tiến trình high_cpu.ps1. Sau khi tiến trình bị dừng, Dashboard Grafana cho thấy mức sử dụng CPU giảm về trạng thái bình thường, chứng minh hệ thống đã xử lý thành công sự cố.

timestamp per 30 minutes

			901 hits
			Jul 17, 2026 @ 23:49:38.103 - Jul 18, 2026 @ 23:49:38.104
Export Formatted	Reset view	878 available fields	Columns Density 1 fields sorted Full screen
timestamp	agent.name	rule.description	
Jul 18, 2026 @ 23:49:11.700	DESKTOP-HNON1K6	Executable file dropped in folder commonly used by malware	
Jul 18, 2026 @ 23:49:11.684	DESKTOP-HNON1K6	Executable file dropped in folder commonly used by malware	
Jul 18, 2026 @ 23:49:11.637	DESKTOP-HNON1K6	Executable file dropped in folder commonly used by malware	
Jul 18, 2026 @ 23:46:26.486	DESKTOP-HNON1K6	Executable file dropped in folder commonly used by malware	
Jul 18, 2026 @ 23:46:26.430	DESKTOP-HNON1K6	Executable file dropped in folder commonly used by malware	
Jul 18, 2026 @ 23:46:26.402	DESKTOP-HNON1K6	Executable file dropped in folder commonly used by malware	
Jul 18, 2026 @ 23:44:49.756	DESKTOP-HNON1K6	Executable file dropped in folder commonly used by malware	
Jul 18, 2026 @ 23:44:49.701	DESKTOP-HNON1K6	Executable file dropped in folder commonly used by malware	

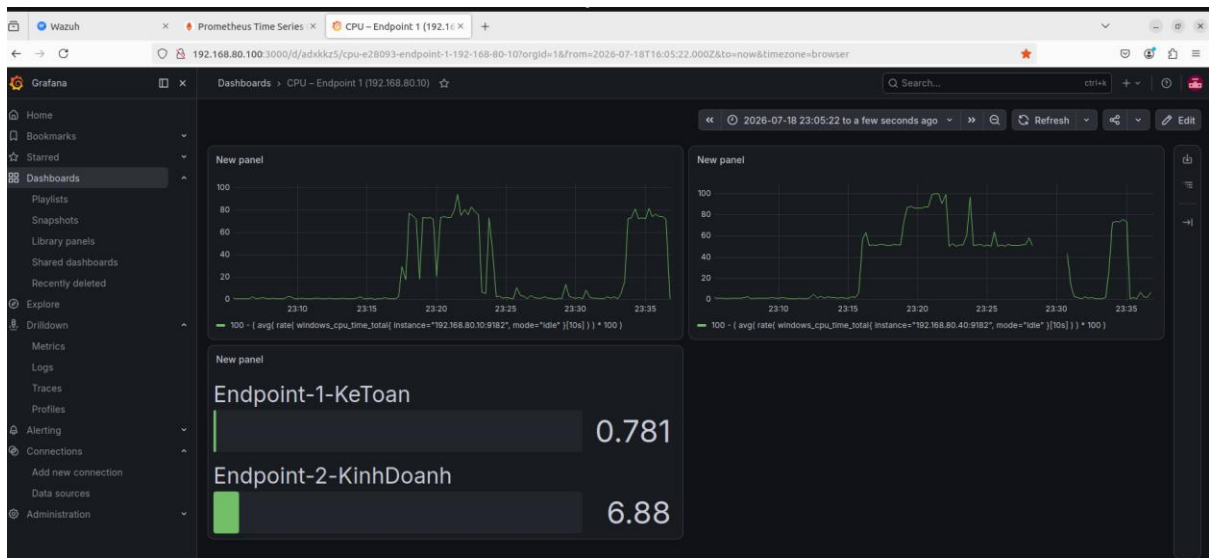
Hình 24. Wazuh hiển thị Process Create

:cTime	
data.win.eventdata.image	C:\\Windows\\System32\\WindowsPowerShell\\v1.0\\powershell.exe
data.win.eventdata.processGuid	{6ea6a7f0-ae87-6a5b-8001-00000001f00}
data.win.eventdata.processId	3116
data.win.eventdata.targetFilename	C:\\Users\\ketoan\\AppData\\Local\\Temp__PSScriptPolicyTest_pbxtocyn.31u.ps1
data.win.eventdata.user	DESKTOP-HNON1K6\\ketoan
data.win.eventdata.utcTime	2026-07-18 16:49:11.143
data.win.system.channel	Microsoft-Windows-Sysmon/Operational
data.win.system.computer	DESKTOP-HNON1K6

Hình 25. Tìm PID của tiến trình đó để end task trên

msiexec.exe	2800	Running
NisSrv.exe	5376	Running
OneDrive.exe	6584	Running
OneDrive.Sync.Servi...	7120	Running
powershell.exe	4056	Running
powershell.exe	7100	Running
powershell.exe	3116	Running
Registry	92	Running
RuntimeBroker.exe	5944	Running
RuntimeBroker.exe	5616	Running
RuntimeBroker.exe	6676	Running
SearchApp.exe	6092	Suspended

Hình 26. End 3 tiến trình 4056, 7100, 3116



Hình 27. Khi end PID, CPU của 2 máy về lại ban đầu

3.4. Tổng hợp kết quả

Bảng 5. Tổng hợp kết quả thực nghiệm

Kịch bản	Phát hiện	Xử lý	Kết quả
EICAR	Defender, Event 1116/1117	Cách ly hoặc xóa	Defender đạt; bổ sung Wazuh
Brute-force RDP	Event 4625 và Wazuh	Khóa tài khoản, giới hạn IP	Đạt phần khóa tài khoản
Tiền trình CPU cao	Task Manager, Sysmon, Wazuh	Dừng PID, quét các máy endpoints	Thấy được CPU tăng bất thường, Wazuh hiện tiến trình được thực hiện và tắt tiến trình trong Task Manager.

3.5. Đánh giá giải pháp

Giải pháp có ưu điểm là chi phí thấp, tận dụng công cụ tích hợp Windows và nền tảng Wazuh mã nguồn mở. Defender và Firewall thực hiện phòng vệ trực tiếp; Sysmon bổ sung dữ liệu tiến trình; Wazuh giúp quản trị viên theo dõi nhiều endpoint tại một giao diện. Mô hình phù hợp doanh nghiệp nhỏ và có thể mở rộng bằng cách cài thêm agent.

Hạn chế của mô hình là Wazuh all-in-one chưa có dự phòng, chưa triển khai Active Directory và quản lý chính sách tập trung, chưa có MFA cho truy cập từ xa và chưa tự động phản ứng toàn bộ. Kịch bản EICAR không đại diện cho mọi loại mã độc, trong khi phát hiện CPU cao vẫn phụ thuộc quan sát thủ công. Môi trường thật nên bổ sung Group Policy, Intune hoặc WSUS, VPN và MFA, phân đoạn mạng, Wazuh Active Response có kiểm soát hoặc một giải pháp EDR thương mại.

CHƯƠNG 4. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

4.1. Kết luận

Đề tài "**Bảo vệ Endpoints cho doanh nghiệp nhỏ**" đã xây dựng và triển khai thành công mô hình bảo vệ endpoint theo nhiều lớp, phù hợp với môi trường doanh nghiệp quy mô nhỏ. Hệ thống sử dụng các thành phần có sẵn của Windows như Microsoft Defender Antivirus, Windows Defender Firewall, Windows Update kết hợp với Sysmon, Wazuh, Prometheus và Grafana nhằm nâng cao khả năng bảo vệ, giám sát và xử lý sự cố trên máy người dùng.

Trong quá trình thực nghiệm, nhóm đã triển khai thành công ba kịch bản chính gồm phát hiện tệp kiểm thử EICAR, mô phỏng tấn công brute-force dịch vụ RDP và phát hiện tiến trình tiêu thụ CPU bất thường. Kết quả cho thấy Microsoft Defender có khả năng phát hiện và xử lý tệp độc hại, Account Lockout Policy giúp hạn chế các cuộc tấn công dò mật khẩu, trong khi Wazuh kết hợp Sysmon hỗ trợ thu thập và phân tích nhật ký để xác định các tiến trình đáng ngờ.

Ngoài ra, việc tích hợp Prometheus và Grafana giúp quản trị viên theo dõi mức sử dụng CPU của các endpoint theo thời gian thực. Khi phát hiện CPU tăng bất thường, Wazuh hỗ trợ điều tra nguyên nhân thông qua các log Sysmon và Wazuh Active Response được sử dụng để xử lý tiến trình gây ra sự cố. Sau khi tiến trình bị dừng, Grafana xác nhận mức sử dụng CPU đã trở về trạng thái bình thường.

Kết quả đạt được cho thấy giải pháp đáp ứng các yêu cầu cơ bản về bảo vệ endpoint cho doanh nghiệp nhỏ, đồng thời chứng minh khả năng kết hợp giữa các công cụ mã nguồn mở và các tính năng bảo mật sẵn có của Windows để xây dựng một hệ thống giám sát và phản ứng sự cố hiệu quả với chi phí thấp.

4.2. Hướng phát triển

Trong tương lai, hệ thống có thể được mở rộng theo các hướng sau:

- Triển khai Active Directory để quản lý tập trung người dùng và Group Policy.
- Triển khai VPN cho người dùng làm việc từ xa.
- Sử dụng Wazuh Active Response để tự động cô lập endpoint khi phát hiện hành vi nguy hiểm.

- Mở rộng hệ thống Prometheus và Grafana để giám sát RAM, Disk, Network và nhiều endpoint hơn.
- Bổ sung Vulnerability Detection của Wazuh để phát hiện các lỗ hổng bảo mật trên endpoint.
- Xây dựng các Sigma Rule và Wazuh Rule tùy chỉnh nhằm phát hiện nhiều kỹ thuật tấn công theo MITRE ATT&CK.
- Tích hợp giải pháp sao lưu và khôi phục dữ liệu nhằm nâng cao khả năng phục hồi sau sự cố.

TÀI LIỆU THAM KHẢO

- [1] Microsoft, Microsoft Defender Antivirus Documentation, <https://learn.microsoft.com/windows/security/threat-protection/microsoft-defender-antivirus>
- [2] Microsoft, Windows Defender Firewall Documentation, <https://learn.microsoft.com/windows/security/operating-system-security/network-security/windows-firewall/>
- [3] Wazuh, Wazuh Documentation, <https://documentation.wazuh.com>
- [4] YouTube. Video hướng dẫn triển khai Grafana và Prometheus. Truy cập từ: https://www.youtube.com/watch?v=__fwMwUpPETo
- [5] YouTube. Video hướng dẫn triển khai Wazuh trong môi trường Windows. Truy cập từ: <https://www.youtube.com/watch?v=TOqoHeDpNcI>